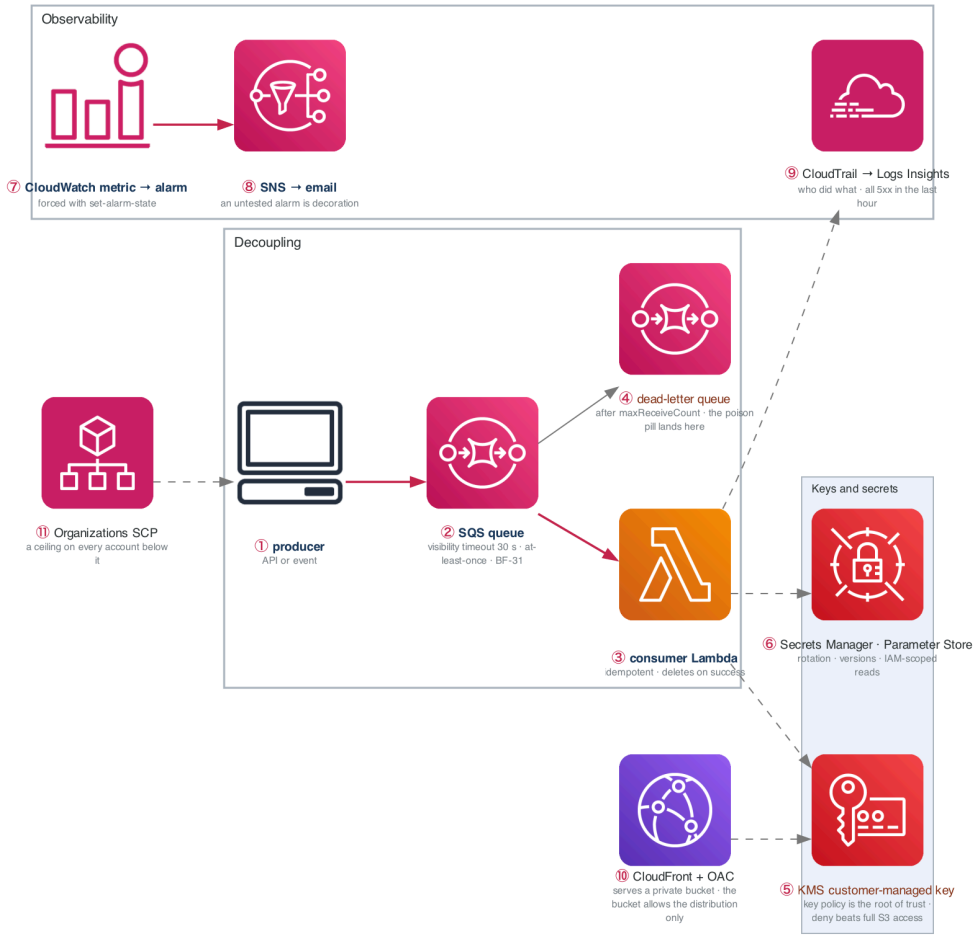
Decouple, encrypt, observe, and know what it costs, numbered

Week 8 · Figure 8.1 · figure with badges 1–11 · 2026-10-17



What to say, badge by badge

About four minutes at a normal pace (452 words). Point at each badge as you say its line.

Open
“The last of the SAA surface area, and the services you will touch every day afterwards. Three small stories: a queue that protects a consumer, a key that can refuse an administrator, and an alarm you do not trust until you have forced it to fire.”

1 **producer**
“Anything that emits work: an API, an event, a schedule. It writes to the queue and returns immediately. It never waits on the consumer.”

2 **SQS queue**
“Messages are delivered at least once. When a consumer reads one, it becomes invisible for the visibility timeout, 30 seconds by default. If the consumer takes longer and does not extend it, the message reappears and is processed twice. That is BF-31, and you reproduce it on purpose.”

3 **consumer Lambda**
“Because delivery is at-least-once, the consumer must be idempotent: doing the work twice must be safe. It deletes the message only after success.”

4 **dead-letter queue**
“A message that fails maxReceiveCount times moves here instead of blocking the queue forever. Send a poison pill and watch it land. Without a DLQ, one bad message can stall everything behind it.”

5 **KMS customer-managed key**
“The key policy, not IAM, is the root of trust for a key. The lab gives a principal full S3 access and then denies it in the key policy. The object reads fail. That is the demonstration that encryption is an access control, not just a checkbox.”

6 **Secrets Manager and Parameter Store**
“Secrets Manager rotates and costs per secret. Parameter Store is cheaper and fine for configuration. Either way, the application reads at runtime with an IAM-scoped call and nothing lives in an environment file.”

7 **CloudWatch alarm**
“A metric crosses a threshold for N periods and the alarm changes state. Force the state with `set-alarm-state` and watch the notification arrive. If you have not forced it, you do not know it works.”

8 **SNS to email**
“The alarm publishes to a topic; the topic fans out to email, SMS, Lambda, or a queue. Confirm the subscription or nothing arrives.”

9 **CloudTrail and Logs Insights**
“CloudTrail is who did what, to which resource, from where. Logs Insights is a query language over log groups. The exit criterion is one query: all 5xx in the last hour.”

10 **CloudFront with OAC**
“A distribution in front of a private bucket. Origin Access Control signs the requests, and the bucket policy allows that distribution and nobody else. The bucket stays private and the content is public.”

11 **Organizations SCP**
“A service control policy is a ceiling applied to every account under an OU. It grants nothing; it only removes. Deny leaving the organization, deny disabling CloudTrail, deny regions you do not use.”

Close
“Four disaster-recovery strategies finish the week, and the one-line version is this: backup and restore is hours and cheap, pilot light is tens of minutes, warm standby is minutes, multi-site is seconds and costs double. RTO and RPO are what you are buying.”